LAPORAN WORKSHOP & DOKUMEN RANCANGAN REST API (v1)

Mata Kuliah: Pemrograman Web Service (Minggu ke-4) | **Dosen:** Zaenul Arif, S.Kom., M.Kom.
Topik: REST API Design: Resource, Endpoint, CRUD, Filtering, Pagination | **Milestone:** M2 – API Blueprint
Aplikasi: SportVenue — Platform Web Service Booking Lapangan Olahraga Online

Identitas Kelompok:	**Kelompok 3 (Kelas TI - Universitas Harkat Negeri 2026/2027)**	**Base URL API:**	http://localhost:8000/api/v1
Anggota & Peran:	1. Moh. Arif Prasetyo (23215043) — *Availability Engine & Discovery* 2. Muhamad Djafar Ilyasa (23215028) — *Auth & User Security* 3. Lutfi Laeli Nur Afiyah (23215046) — *Core Booking & Concurrency Lock* 4. Muh. Kharis Maulana Elhaq (23215059) — *Payment Gateway & Webhook*	**Spesifikasi:**	• Standar: RESTful JSON API • Autentikasi: Sanctum Bearer Token • Versioning: Path-based (/api/v1) • Konvensi: English (Plural, Kebab-case)

20.1 Aktivitas 1 – Pemodelan Resource (15 menit)

Resource diturunkan dari kebutuhan fungsional dan kata benda (*nouns*) pada proses bisnis SportVenue: pencarian lapangan, pengecekan matriks slot jam, reservasi booking, pembayaran DP Midtrans, dan kebijakan pembatalan sewa.

No	Resource (Jamak)	Atribut Utama	Relasi Antar Entitas	Jenis Resource
1	**venues**	id, owner_id, name, slug, address, city, phone, dp_percent, cancel_free_hours, cancel_refund_percent, is_active	1 : N ke courts N : 1 ke users (owner)	Collection
2	**courts**	id, venue_id, name, sport_type, surface, capacity_players, is_active	N : 1 ke venues 1 : N ke court_prices, operating_hours, bookings	Sub-resource / Collection
3	**court_prices**	id, court_id, day_type, start_time, end_time, price, label	N : 1 ke courts	Sub-resource
4	**operating_hours**	id, court_id, day_of_week, open_time, close_time, is_closed	N : 1 ke courts	Sub-resource
5	**schedule_blocks**	id, court_id, start_at, end_at, block_type, reason, created_by	N : 1 ke courts N : 1 ke users	Sub-resource
6	**bookings**	id, code, user_id, court_id, play_date, total_price, dp_amount, status, expires_at	N : 1 ke users, N : 1 ke courts 1 : N ke booking_slots, 1 : N ke payments	Collection
7	**payments**	id, booking_id, order_id, type, amount, status, snap_token, redirect_url	N : 1 ke bookings	Sub-resource / Collection
8	**me**	id, name, email, phone, role, status, created_at	N/A (merujuk ke profil pengguna terautentikasi)	Singleton
9	**booking_slots**	id, booking_id, court_id, slot_start, slot_end	N : 1 ke bookings unique(court_id, slot_start)	Internal Engine (Anti-Collision)

Diagram Relasi Sederhana Antar-Resource (ERD Ringkas):

```
[users] 1 ■■■■■■■■■■■■ N [venues] 1 ■■■■■■■■■■■■ N [courts] 1 ■■■■ N [court_prices] ■ ■ 1 ■■■■ N [operating_hours] ■
■ 1 ■■■■ N [schedule_blocks] ■ 1 ■ 1 ▼ N ▼ N [bookings] 1 ■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■■ N [booking_slots]
(InnoDB Unique Index: anti double-booking) ■ 1 ▼ N [payments] (Midtrans Snap Token & Webhook Callback Idempotent)
```

20.2 Aktivitas 2 – Endpoint Matrix (20 menit)

Disusun 25 endpoint RESTful lengkap mencakup seluruh modul operasional SportVenue. Setiap baris memuat HTTP method semantik, path URI terstandar, fungsi operasi, aktor pengguna, serta status sukses dan status gagal yang relevan:

No	Method	Endpoint (Base: /api/v1)	Fungsi & Operasi Bisnis	Aktor	Sukses	Status Gagal Relevan
1	**POST**	/auth/register	Registrasi pengguna baru (penyewa aktif, pengelola pending)	Publik	**201 Created**	400, 422
2	**POST**	/auth/login	Autentikasi akun & penerbitan Sanctum Bearer Token	Publik	**200 OK**	401, 422
3	**POST**	/auth/logout	Revokasi token autentikasi aktif pengguna	Login	**204 No Content**	401
4	**GET**	/me	Mengambil profil pengguna yang sedang login (singleton)	Login	**200 OK**	401
5	**GET**	/venues	Katalog venue mitra dengan filter city, sport_type, q, pagination	Publik	**200 OK**	400, 422
6	**GET**	/venues/{id}	Detail satu venue beserta daftar fasilitas lapangan fisiknya	Publik	**200 OK**	404
7	**GET**	/venues/{id}/courts	Daftar lapangan pada venue tertentu (sub-resource)	Publik	**200 OK**	404
8	**GET**	/courts/{id}	Detail spesifikasi teknis lapangan (tipe lantai, ukuran, foto)	Publik	**200 OK**	404
9	**GET**	/courts/{id}/prices	Daftar struktur harga sewa lapangan (reguler, peak, weekend)	Publik	**200 OK**	404
10	**GET**	/courts/{id}/availability	Matriks ketersediaan slot jam & tarif per tanggal (YYYY-MM-DD)	Publik	**200 OK**	404, 422
11	**POST**	/bookings	Reservasi booking baru, kunci slot atomik, hold DP 15 menit	Penyewa	**201 Created**	400, 409, 422
12	**GET**	/bookings	Riwayat transaksi booking milik penyewa yang sedang login	Penyewa	**200 OK**	401
13	**GET**	/bookings/{id}	Detail faktur booking, slot yang diambil, dan rincian bayar	Penyewa, Pengelola	**200 OK**	401, 403, 404
14	**POST**	/bookings/{id}/payments	Membuat transaksi DP Midtrans Snap token & redirect URL	Penyewa	**201 Created**	401, 403, 409
15	**POST**	/bookings/{id}/cancellation	Membatalkan booking & hitung refund otomatis kebijakan venue	Penyewa	**200 OK**	401, 403, 409
16	**POST**	/payments/webhook/midtrans	Callback webhook notifikasi gateway (verifikasi HMAC SHA-512)	Midtrans	**200 OK**	401, 403
17	**POST**	/manage/courts	Menambah lapangan baru pada venue milik pengelola	Pengelola	**201 Created**	401, 403, 422
18	**PUT**	/manage/courts/{id}	Memperbarui data spesifikasi lapangan secara menyeluruh	Pengelola	**200 OK**	401, 403, 404, 422
19	**PATCH**	/manage/courts/{id}	Mengubah status aktif/non-aktif lapangan parsial	Pengelola	**200 OK**	401, 403, 404
20	**DELETE**	/manage/courts/{id}	Menghapus/menonaktifkan lapangan fisik dari sistem	Pengelola	**204 No Content**	401, 403, 404, 409
21	**POST**	/manage/courts/{id}/blocks	Membuat blokir slot perawatan/event (schedule blocks)	Pengelola	**201 Created**	401, 403, 422
22	**DELETE**	/manage/blocks/{id}	Membatalkan jadwal pemblokiran lapangan fisik	Pengelola	**204 No Content**	401, 403, 404
23	**PATCH**	/manage/bookings/{id}/status	Mengubah status sewa lapangan menjadi COMPLETED / NO_SHOW	Pengelola	**200 OK**	401, 403, 422
24	**GET**	/admin/users	Daftar seluruh akun pengguna platform dengan filter role & status	Admin	**200 OK**	401, 403
25	**PATCH**	/admin/users/{id}/verify	Verifikasi dan aktivasi kemitraan akun pengelola venue baru	Admin	**200 OK**	401, 403, 404

20.3 Aktivitas 3 – Desain Query untuk Endpoint Collection (15 menit)

Ditetapkan query parameter standar pada 3 endpoint collection untuk menyaring (*filter*), mencari (*search*), mengurutkan (*sort*), dan memaginasi (*pagination*) dengan whitelist ketat:

Endpoint Collection	Filter (Whitelist)	Search	Sort (Default & Whitelist)	Pagination (Default / Maks)
GET /venues /api/v1/venues	• city (string) • sport_type (futsal, badminton, basket, mini_soccer) • is_active (boolean) • min_price, max_price	q (mencari pada name, address, city)	• Default: name • Whitelist: name, -name, created_at, -created_at, starting_price, -starting_price	Model: Offset-based Param: page, per_page • Default: **10** • Maksimum: **50**
GET /bookings /api/v1/bookings	• status (PENDING_PAYMENT, CONFIRMED, COMPLETED, CANCELLED, EXPIRED) • court_id (integer) • date_from, date_to	q (mencari kode booking: code, misal BK-20261011)	• Default: -created_at • Whitelist: created_at, -created_at, play_date, -play_date, total_price	Model: Offset-based Param: page, per_page • Default: **15** • Maksimum: **100**
GET /admin/users /api/v1/admin/users	• role (penyewa, pengelola, admin) • status (active, pending, suspended)	q (mencari pada name, email, phone)	• Default: -created_at • Whitelist: name, -name, email, created_at, -created_at	Model: Offset-based Param: page, per_page • Default: **20** • Maksimum: **100**

20.4 Aktivitas 4 – Peer Review & Quality Checklist (10 menit)

Evaluasi kelayakan kontrak rancangan API SportVenue mengacu pada 8 butir standar industri perancangan RESTful API:

No	Butir Pemeriksaan Kualitas Desain REST API	Status	Catatan Evaluasi Kelompok & Hasil Penilaian
1	Semua URI memakai kata benda jamak, huruf kecil, dan tanpa kata kerja	**[X] Ya**	Seluruh endpoint memakai kata benda jamak (/venues, /courts, /bookings, /payments). Tidak ditemukan kata kerja seperti /getVenues atau /createBooking.
2	Prefix /api/v1 dipakai konsisten	**[X] Ya**	Seluruh URI diawali prefix /api/v1, memastikan evolusi API tanpa memutus (*breaking*) integrasi client lama.
3	Method sesuai operasi; GET tidak mengubah data	**[X] Ya**	Operasi GET bersifat *safe & idempotent* (hanya membaca data). Seluruh mutasi state wajib memakai POST (create), PUT/PATCH (update), atau DELETE.
4	POST → 201, DELETE → 204, dan status gagal relevan dicantumkan	**[X] Ya**	Create menghasilkan 201 Created disertai header Location; Delete menghasilkan 204 No Content. Status gagal (400, 401, 403, 404, 409, 422) didefinisikan lengkap.
5	Nesting maksimal 2 tingkat	**[X] Ya**	Nesting dibatasi: /venues/{id}/courts. Setelah item memiliki ID unik global, akses dilakukan secara flat: /courts/{id}, /bookings/{id}.
6	Setiap collection memiliki pagination dengan batas maksimum	**[X] Ya**	Setiap collection dibatasi default 10–20 dan hard-cap max 50–100 untuk menangkal celah OWASP *Unrestricted Resource Consumption*.
7	Filter/sort memakai query parameter dengan whitelist	**[X] Ya**	Filter dan sort dioperasikan di query string dengan whitelist ketat untuk mencegah SQL error atau kebocoran kolom internal sensitif.
8	Format error seragam	**[X] Ya**	Seluruh skenario kegagalan memakai amplop format seragam: { status: 'error', message: '...', errors: { ... } }.

Tindak Lanjut Perbaikan Pasca Peer Review:
1. Menambahkan validasi regex ISO 8601 YYYY-MM-DD pada endpoint availability /courts/{id}/availability?date=.
2. Membatasi representasi JSON DTO agar tidak pernah mengekspos atribut sensitif database internal (password, remember_token) demi kepatuhan OWASP API3 (Broken Object Property Level Authorization).
3. Memastikan arsitektur *Anti Double Booking* (§9.2 PRD) selalu merespons dengan HTTP status 409 Conflict saat terjadi tabrakan transaksi reservasi konkuren.

Representasi Response JSON & Format Error Terstandar

Format representasi data keluaran Laravel API Resource seragam untuk seluruh endpoint (envelope data, meta, dan links):

Response Item Tunggal & Error Validasi 422:

```
// 1. Response Item Tunggal (GET /api/v1/venues/1) {
"status": "success", "data": { "id": 1, "name": "Arena Garuda
Futsal", "slug": "arena-garuda-futsal", "city": "Tegal",
"dp_percent": 30, "cancel_free_hours": 24,
"cancel_refund_percent": 50 } } // 2. Response Validasi Gagal
(422 Unprocessable Content) { "status": "error", "message":
"Data yang dikirim tidak valid.", "errors": { "slots":
["Minimal satu slot jam harus dipilih."] } }
```

Response Koleksi Pagination & Conflict 409:

```
// 3. Response Koleksi dengan Pagination (GET /venues) {
"status": "success", "data": [ { "id": 1, "name": "Arena
Garuda Futsal", "city": "Tegal", "starting_price": 120000 }, {
"id": 2, "name": "GOR Satria Badminton", "city": "Tegal",
"starting_price": 40000 } ], "links": { "first":
"http://localhost:8000/api/v1/venues?page=1", "last":
"http://localhost:8000/api/v1/venues?page=3", "prev": null,
"next": "http://localhost:8000/api/v1/venues?page=2" },
"meta": { "current_page": 1, "per_page": 2, "total": 6,
"last_page": 3 } } // 4. Response Aturan Bisnis Bentrok Slot
(409 Conflict) { "status": "error", "message": "Satu atau
lebih slot sudah terisi atau sedang di-hold. Silakan pilih
slot lain.", "code": "SLOT_ALREADY_LOCKED" }
```

Pola Aksi Non-CRUD & Catatan Keputusan Desain Arsitektur

- **Aksi Non-CRUD Pembatalan Booking (POST /bookings/{id}/cancellation):** Dimodelkan menggunakan pola *Sub-resource / Process as Resource*. Pembatalan sewa lapangan bukan sekadar PATCH status = cancelled, melainkan memerlukan evaluasi audit trail kebijakan pembatalan venue (perhitungan tenggat waktu H-24/H-12, persentase refund DP, pelepasan kunci baris slot operasional di database, dan notifikasi refund ke penyewa).
- **Aksi Non-CRUD Pembayaran DP (POST /bookings/{id}/payments):** Dipisahkan menjadi sub-resource pembayaran karena memiliki entitas data mandiri (order_id Midtrans, status token Snap, redirect URL, dan verifikasi callback webhook idempotent).
- **Dukungan PUT vs PATCH:** Keduanya didukung pada endpoint /manage/courts/{id}. PUT menggantikan seluruh representasi data lapangan, sedangkan PATCH dipergunakan untuk pembaruan atribut tunggal secara atomik (misalnya mengubah status aktif/non-aktif lapangan is_active).
- **Strategi Versioning:** Menggunakan path-based versioning (/api/v1) yang mudah dipahami, mudah diuji via Postman, dan secara transparan memisahkan kontrak versi lama jika di kemudian hari dilakukan breaking change.
- **Struktur Envelope Data & Pagination:** Menggunakan format { status, data, links, meta } yang selaras dengan keluaran standar Laravel Eloquent API Resource, mempermudah tim frontend/mobile dalam rendering navigasi halaman.